

Kronos - Sistema de Controle de Ponto

Data: 29 de agosto de 2026

Escopo: Código-fonte backend Java (1017 arquivos)

Classificação: Confidencial - Uso interno restrito

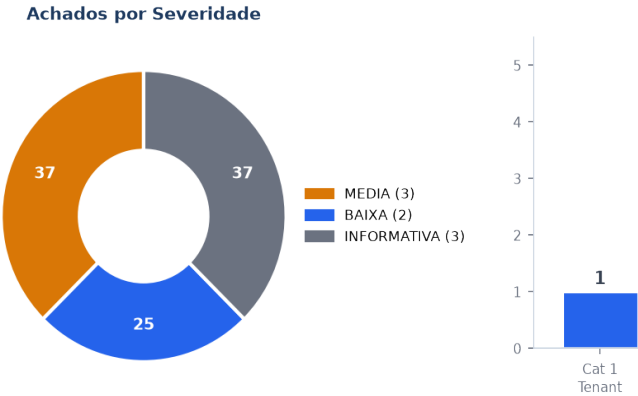


Stack	Java 21 / Spring Boot 3.5 / PostgreSQL / Redis / AWS S3+Rekognition / iTextPDF
Arquitetura	Hexagonal: controllers em adapter/in/web/http/, services em application/service/
Tenant isolation	activeCompanyId no JWT, validado em DomainAuthorizationService por cada operacao
Frontend	Nao auditado (repositorio separado). Achados XSS backend anotados.
Nao auditados	.env e infra/observability/.env (permissao negada)

1. Resumo Executivo

A auditoria analisou **8 achados** no backend Kronos (1017 arquivos Java). Nenhum achado CRITICO ou ALTO. Os dois achados MEDIA referem-se a role TERMINAL sem restricao de role e dado pessoal (CPF/CNPJ) hardcoded. DomainAuthorizationService elimina a classe inteira de IDOR e cross-tenant.

Severidade	Qtd
CRITICA	0
ALTA	0
MEDIA	3
BAIXA	2
INFORMATIVA	3
TOTAL	8



2. Pontos Fortes e Fracos

2.1 Pontos Fortes

OK

Autorizacao centralizada via DomainAuthorizationService Unico ponto de verificacao de tenant/ownership. Nenhum service bypassou nos caminhos criticos.

OK

Isolamento de tenant em todos os recursos criticos TimeRecord, Document, LGPD, Schedule e PointMirror verificam tenant antes de qualquer leitura/escrita.

OK

IDOR inexistente nos recursos de dados Services realizam verificacao explicita de assignment e tenant, eliminando IDOR cruzado.

OK

Producao sem secrets hardcoded application-prod.yml exige todas as env vars sem fallback. ProductionConfigValidator invalida startup com JWT < 64 chars.

OK

Session invalidation e token blacklist JwtAuthenticationFilter verifica session_version. Troca de senha invalida todos os tokens. Blacklist para logout.

OK

Sanitizacao de dados sensiveis em observabilidade FrontendObservabilitySanitizer, SensitiveDataSanitizer e SensitiveDataMasker removem CPF, email, JWT de todos os logs.

OK

PDFs gerados via API binaria (sem HTML injection) ReceiptPdfService, PointMirrorPdfService usam API Java do iTextPDF, eliminando risco de XSS em PDFs.

OK

Verificacao biometrica em operacoes criticas sign() em contratos e espelhos exigem reconhecimento facial via AWS Rekognition com verificacao de identidade.

OK

Rate limiting em endpoints sensiveis Login, recovery e checkin biometrico tem rate limits com cooldown progressivo via Redis.

OK

CSRF configurado CookieCsrfTokenRepository com excecoes apenas para endpoints de autenticacao stateless.

OK

Actuator restrito em producao Limitado a health, info, prometheus; vinculado a 127.0.0.1:8081, inacessivel externamente.

2.2 Pontos Fracos

MED

ACHADO-001 - CPF/CNPJ reais compilados no JAR e historico git - risco LGPD.

MED

ACHADO-004/005 - Role TERMINAL acessa contratos e espelhos via isAuthenticated() sem restricao de role.

INF

ACHADO-007 - Backend nao sanitiza HTML em mensagens - depende do frontend nao auditado.

INF

ACHADO-008 - Numero INPI placeholder (999999999) em documentos fiscais com validade juridica.

3. Achados Detalhados

ACHADO-001		MEDIA	Cat 4 - Chaves expostas
Titulo	CPF e CNPJ reais hardcoded em constante de producao		
Arquivo	constants/LegalCompanyData.java linha(s) 7-8		
Problema	DEV_RAZAO_SOCIAL e DEV_CNPJ contem CPF e CNPJ reais compilados no JAR. O comentario da classe instrui mover para application.yml, mas nao foi feito. O dado persiste em historico git, imagens Docker e no binario distribuido.		
Trecho	<pre>public static final String DEV_CNPJ = "66.899.562/0001-27";</pre>		
Impacto	Exposicao de CPF/CNPJ. Risco de violacao de LGPD Art. 46.		
Explorabilidade	Qualquer pessoa com acesso ao repositorio ou JAR pode extrair via strings ou bytecode.		

ACHADO-002		BAIXA	Cat 4 - Chaves expostas
Titulo	Defaults fracos para HMAC Redis, hash LGPD e sandbox-key		
Arquivo	src/main/resources/application.yml linha(s) 165, 218, 232		
Problema	Tres propriedades tem fallbacks fracos via \${VAR:-default}: REDIS_KEY_HMAC_SECRET, LGPD_LOG_HASH_SECRET e KRONOS_DEMO_SANDBOX_KEY. Em staging ou CI sem vars definidas, os valores fracos sao usados silenciosamente.		
Trecho	<pre>key-hmac-secret: \${REDIS_KEY_HMAC_SECRET:local-dev-redis-key-secret}</pre>		
Impacto	HMAC de chaves Redis forjavel; hash LGPD previsivel em staging.		
Explorabilidade	Requer sistema rodando sem as env vars definidas (staging, CI mal configurado).		

ACHADO-003		BAIXA	Cat 4 - Chaves expostas
Titulo	Perfil local expoe Actuator endpoints e JWT secret fraco		
Arquivo	src/main/resources/application-local.yml linha(s) 73, 77, 93		
Problema	O perfil 'local' inclui endpoints Actuator env e configprops, exhibe health details=always e usa JWT secret com fallback fraco. Se ativado em ambiente nao-isolado, expoe todas as variaveis de ambiente.		
Trecho	<pre>include: "env,configprops" show-details: always secret: \${JWT_SECRET:local-dev-secret...}</pre>		
Impacto	Exposicao de configuracao sensivel via /actuator/env se perfil local ativado em producao.		
Explorabilidade	Requer ativacao acidental do perfil 'local' em producao ou staging acessivel.		

ACHADO-004	MEDIA	Cat 2 - Permissao insuficiente
Titulo	Role TERMINAL pode acessar endpoints de contratos de servico	
Arquivo	adapter/in/web/http/ServiceContractController.java linha(s) 87, 93-94, 105-106, 117-118	
Problema	Quatro endpoints (findMyPending, preview, sign, downloadSignedDocument) usam @PreAuthorize('isAuthenticated()') em vez de hasAnyRole('MANAGER','PARTNER','CTO'). Role TERMINAL e autenticada mas representa quiosque - nao deve acessar contratos. findMyPending() e preview() nao tem verificacao biometrica compensatoria.	
Trecho	<pre>@PreAuthorize("isAuthenticated()") @GetMapping(SERVICE_CONTRACT_ME_PENDING) public ResponseEntity findMyPending() {...}</pre>	
Impacto	Token TERMINAL pode listar contratos pendentes e baixar PDFs de contrato.	
Explorabilidade	Requer token JWT com role TERMINAL (acesso ao quiosque ou credencial comprometida).	

ACHADO-005	MEDIA	Cat 2 - Permissao insuficiente
Titulo	Role TERMINAL pode acessar endpoints de assinatura de espelho de ponto	
Arquivo	adapter/in/web/http/TimesheetSignatureController.java linha(s) 43-44, 52-53, 71-72, 82-83	
Problema	Quatro endpoints (status, preview, sign, downloadDocument) usam isAuthenticated(). status() e preview() nao tem verificacao biometrica compensatoria, permitindo que token TERMINAL consulte status e baixe PDFs mensais.	
Trecho	<pre>@PreAuthorize("isAuthenticated()") @GetMapping(TIMESHEET_SIGNATURE_STATUS) public ResponseEntity status(...) {...}</pre>	
Impacto	Token TERMINAL pode consultar status de assinatura e baixar espelhos de ponto mensais.	
Explorabilidade	Mesma condicao que ACHADO-004.	

ACHADO-006	INFORMATIVA	Cat 1 - Isolamento de tenant
Titulo	Fallback silencioso de activeCompanyId para empresa primaria em tokens legados	
Arquivo	application/security/DomainAuthorizationService.java linha(s) 103-108	
Problema	Quando activeCompanyId e null no token, o fallback usa employee.companyId() - a empresa primaria. Em cenario multi-company, tokens legados sem activeCompanyId sempre resolvem para empresa primaria sem indicar o problema.	
Trecho	<pre>if (activeCompanyId == null) { activeCompanyId = getAuthenticatedEmployee().companyId(); }</pre>	
Impacto	Autorizacao silenciosamente incorreta para usuarios multi-empresa com tokens legados.	
Explorabilidade	Requer token emitido via overload sem activeCompanyId. Nao permite cross-tenant.	

ACHADO-007		INFORMATIVA	Cat 5 - Inputs sem tratamento
Titulo	Conteudo de mensagens armazenado sem sanitizacao HTML no backend		
Arquivo	application/service/MessageService.java linha(s) 140-146		
Problema	title e messageText sao armazenados sem sanitizacao HTML/XSS. A seguranca depende inteiramente do frontend escapar corretamente. Risco de XSS stored se frontend renderizar via innerHTML ou equivalente.		
Trecho	<pre>var message = new Message(sender.employeeId(), senderCompanyId, request.title(), // sem sanitizacao request.messageText(), // sem sanitizacao ...);</pre>		
Impacto	XSS stored se frontend renderizar sem escape. Severidade real depende do frontend.		
Explorabilidade	Requer: (a) MANAGER/CTO criar mensagem com payload XSS, E (b) frontend renderizar sem escape.		

ACHADO-008		INFORMATIVA	Cat 4 - Chaves expostas
Titulo	Numero INPI placeholder '999999999' em documentos com validade juridica		
Arquivo	constants/LegalCompanyData.java + service/ReceiptPdfService.java linha(s) 11 / 27		
Problema	Numero de registro INPI ficticio (999999999) hardcoded em dois lugares. PDFs de recibo emitidos em producao incluem esse numero, o que pode configurar uso indevido sob Portaria 671/2021.		
Trecho	<pre>public static final String INPI_NUMBER = "999999999";</pre>		
Impacto	Risco de conformidade legal: documentos fiscais com numero INPI invalido.		
Explorabilidade	Nao e exploravel por atacante externo; e problema de conformidade interna.		

4. Recomendacoes Priorizadas

P1	Remover CPF/CNPJ de LegalCompanyData.java ACHADO-001	Mover para variaveis de ambiente ou cofre de segredos. Executar git filter-repo para remover do historico. Avaliar notificacao a ANPD (LGPD Art. 48).
P1	Substituir isAuthenticated() por ANY_EMPLOYEE nos 8 endpoints ACHADO-004/005	Alterar para hasAnyRole('MANAGER','PARTNER','CTO') em ServiceContractController (4 endpoints) e TimesheetSignatureController (4 endpoints). Adicionar testes com token TERMINAL para garantir HTTP 403.
P2	Substituir numero INPI placeholder por valor real ACHADO-008	Definir numero INPI real ou criar issue de rastreamento com prazo. PDFs fiscais com numero ficticio representam risco de conformidade com Portaria 671/2021.
P2	Sanitarizar conteudo de mensagens no backend ACHADO-007	Usar Jsoup.clean() para strip de HTML em request.title() e request.messageText() antes de persistir. Independente da seguranca do frontend.
P3	Garantir env vars definidas em todos os ambientes nao-producao ACHADO-002/003	Revisar pipelines CI/CD e staging para garantir que REDIS_KEY_HMAC_SECRET e LGPD_LOG_HASH_SECRET estejam sempre definidas.

5. Issues para o GitHub

Textos completos prontos para copiar e colar. Cada bloco delimitado por marcadores.

ISSUE 1 - [Seguranca] CPF e CNPJ reais hardcoded em LegalCompanyData.java

Labels: security, media

--- ISSUE 1 ---

```
## Problema
CPF e CNPJ reais estao hardcoded nas constantes DEV_RAZAO_SOCIAL e DEV_CNPJ em
LegalCompanyData.java, compilados no JAR e no historico git.

## Por que e exploravel
Qualquer pessoa com acesso ao repositorio ou ao JAR pode extrair CPF/CNPJ via `strings` ou inspecao
de bytecode, sem autenticacao no sistema.

## Evidencia
...
constants/LegalCompanyData.java linhas 7-8:
public static final String DEV_CNPJ = "66.899.562/0001-27";
...

(O comentario na linha 6 ja instrui mover para application.yml -- nao foi feito.)

## Impacto
Violacao potencial do Art. 46 da LGPD. Risco de notificacao obrigatoria a ANPD se repositorio
acessivel externamente (Art. 48).

## Sugestao de correcao
1. Mover para variaveis de ambiente ou cofre de segredos
2. Injetar via @Value com validacao no ProductionConfigValidator
3. Executar git filter-repo para remover o dado do historico
4. Avaliar comunicacao a ANPD

## Criterios de aceite
- [ ] Constantes removidas de LegalCompanyData.java
- [ ] Valores injetados via env var com validacao de startup
- [ ] Historico git reescrito sem os dados
- [ ] Testes de startup falham se env vars ausentes em producao
```

--- FIM ISSUE 1 ---

ISSUE 2 - [Seguranca] Role TERMINAL pode acessar contratos e espelhos de ponto

Labels: security, media

--- ISSUE 2 ---


```
## Problema
8 endpoints em ServiceContractController e TimesheetSignatureController usam
@PreAuthorize("isAuthenticated()") em vez de hasAnyRole('MANAGER','PARTNER','CTO'). A role TERMINAL
representa quiosque biometrico e nao deve ter acesso a esses recursos.

## Evidencia
...

ServiceContractController.java linha 87:
@PreAuthorize("isAuthenticated()")
public ResponseEntity findMyPending() {...}

TimesheetSignatureController.java linha 43:
@PreAuthorize("isAuthenticated()")
public ResponseEntity status(...) {...}
...

## Impacto
Token TERMINAL pode: listar contratos pendentes, baixar PDFs de contrato, consultar status de
assinatura e baixar espelhos mensais.

## Sugestao de correcao
Substituir isAuthenticated() por hasAnyRole('MANAGER', 'PARTNER', 'CTO') nos 8 endpoints:
- ServiceContractController: findMyPending, preview, sign, downloadSignedDocument
- TimesheetSignatureController: status, preview, sign, downloadDocument

## Criterios de aceite
- [ ] Todos os 8 endpoints retornam HTTP 403 para tokens com role TERMINAL
- [ ] Testes de integracao cobrindo cenarios com token TERMINAL
- [ ] Fluxo de assinatura biometrica mantido via caminho correto
```

--- FIM ISSUE 2 ---

ISSUE 3 - [Seguranca] Numero INPI placeholder + defaults fracos em ambientes nao-prod

Labels: security, baixa, informativa

--- ISSUE 3 ---

Este issue agrupa dois achados de baixa/informativa.

3a - Numero INPI ficticio em documentos fiscais

...

LegalCompanyData.java linha 11:

```
public static final String INPI_NUMBER = "999999999";
```

ReceiptPdfService.java linha 27:

```
private static final String INPI_REGISTRATION_NUMBER = "999999999";
```

...

PDFs de recibo emitidos em producao incluem numero ficticio. Documentos sob Portaria 671/2021 com INPI invalido representam risco de conformidade.

Acao: Definir numero INPI real ou criar issue de rastreamento com prazo.

3b - Defaults fracos em ambientes nao-producao

...

application.yml linhas 165, 218, 232:

```
key-hmac-secret: ${REDIS_KEY_HMAC_SECRET:local-dev-redis-key-secret}
```

```
hash-secret: ${LGPD_LOG_HASH_SECRET:local-dev-lgpd-log-secret}
```

...

Em staging ou CI sem as variaveis definidas, valores fracos sao usados silenciosamente.

Acao: Garantir que as env vars estejam definidas em todos os pipelines.

Critérios de aceite

- [] Numero INPI real definido ou issue de rastreamento criada
- [] Pipeline CI/CD valida presenca de REDIS_KEY_HMAC_SECRET e LGPD_LOG_HASH_SECRET
- [] Documentacao de perfis por ambiente atualizada

--- FIM ISSUE 3 ---

ISSUE 4 - [Seguranca] Conteudo de mensagens sem sanitizacao HTML (defesa em profundidade)

Labels: security, informativa

--- ISSUE 4 ---

Problema

title e messageText em MessageService.java sao armazenados sem sanitizacao HTML/XSS. A seguranca depende do frontend escapar corretamente.

Evidencia

```

MessageService.java linhas 140-146:

```
var message = new Message(
 sender.employeeId(), senderCompanyId,
 request.title(), // sem sanitizacao
 request.messageText(), // sem sanitizacao
 ...
);
```
```

Impacto

XSS stored para todos os destinatarios se frontend renderizar sem escape. Severidade depende da implementacao do frontend (nao auditado).

Sugestao de correcao

Adicionar sanitizacao com Jsoup como defesa em profundidade:

```
```java  
// org.jsoup:jsoup
String safeTitle = Jsoup.clean(request.title(), Safelist.none());
String safeText = Jsoup.clean(request.messageText(), Safelist.basic());
```
```

Criterios de aceite

- [] Sanitizacao implementada em MessageService
- [] Testes unitarios validando strip de tags HTML
- [] Frontend auditado separadamente

--- FIM ISSUE 4 ---